



Know what your agents can do.

Make your agents insurable. Start by writing down what each one can actually reach, what you authorised it to do, and the gap between the two.

ONE PUBLISHED POLICY, COUNTED

Nine things it can do that nobody asked for.

Claude Code on the web, with one repository attached.
Every number decrypted from the vault that describes
it, and the vault is published with its read key.

15

capabilities it can reach

6

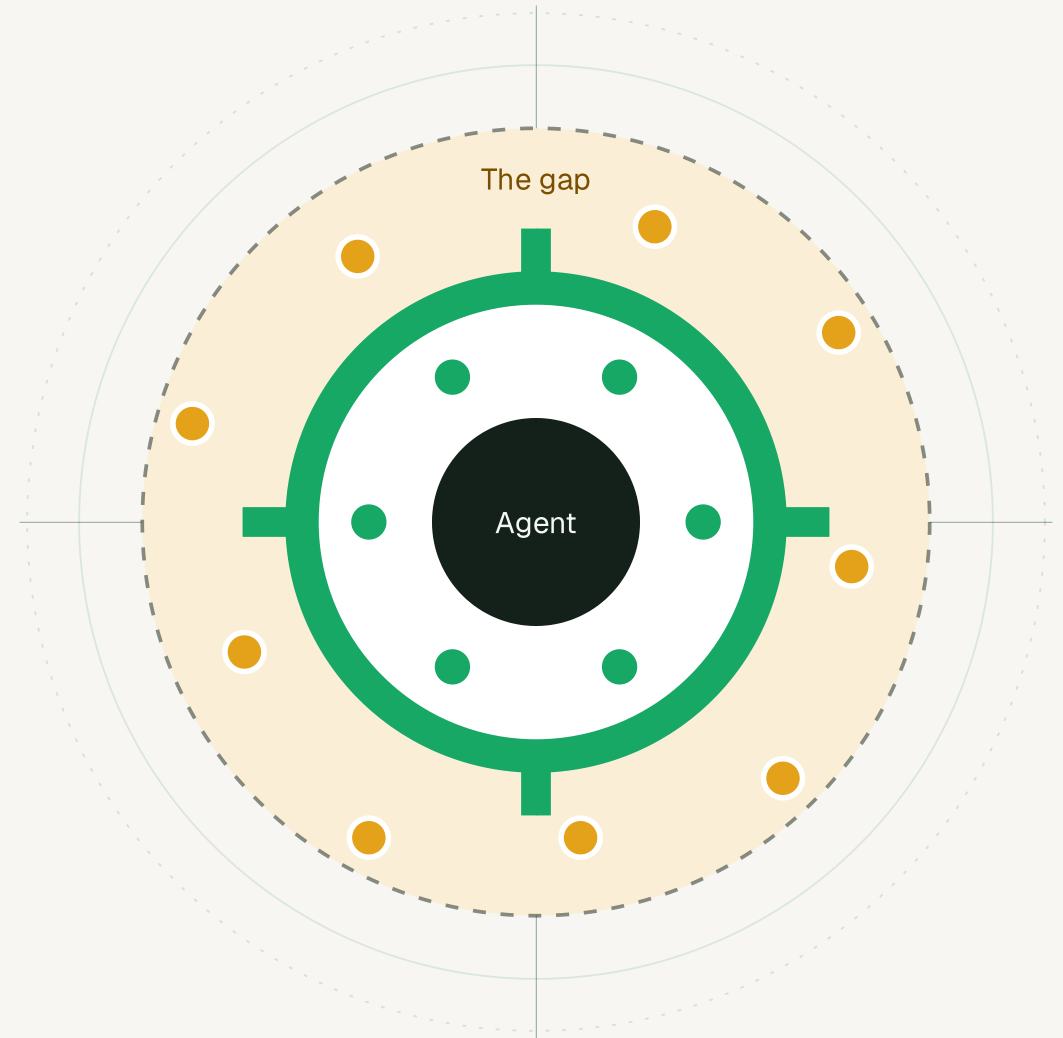
that you actually asked for

9

it can do that you didn't ask for

7

with nothing real in the way



NOT A MODEL PROPERTY

The same model is harmless in one setup and serious in another.

Connect it to a mailbox and the narrowest Gmail scope that reads one message reads every message. Nothing about the model changed; the deployment did.

So risk is a property of the deployment, and the record has to be fitted to the deployment it describes. That is why the unit is one agent, in one place, not a model or an estate.

WHAT AN AGENT BEHAVIOUR POLICY IS

Four objects, and only one of them is an opinion.

MEASURED

Reach

Everything the agent can actually access in this deployment, including what nobody thought to check.

ELICITED

Mandate

The job, written down: what the business authorised it to do. The one part only you can supply.

DERIVED

Gap

Reach minus mandate. Never written by hand, and recomputed whenever either side moves.

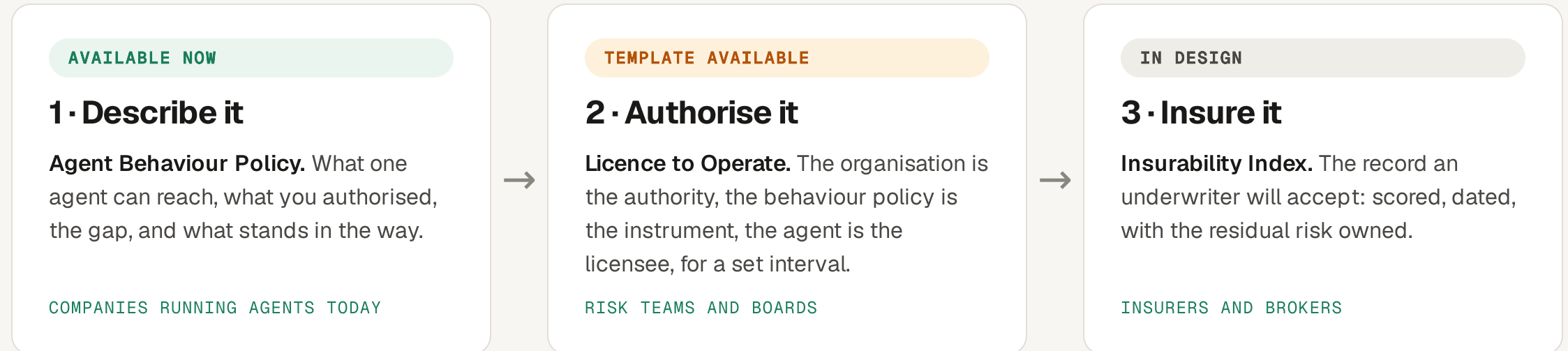
RECORDED

Barriers

What actually stands in the way of each capability: controls, constraints and open questions.

A behaviour policy describes and carries no score. What is acceptable is a decision, and the decision belongs to the people who answer for the agent.

Make agents insurable. The behaviour policy is where every agent starts.



Each step needs the one before it, and each one is sold to the people it serves. The destination is agent risk at a level the board has accepted and can show – which, for high-risk AI systems, is what the EU AI Act asks for: residual risk *judged to be acceptable* (Regulation (EU) 2024/1689, Article 9(5)).

Help companies control and manage the agents they already run.

TODAY

Describe and correct

One agent, one deployment, written down and argued with by the people who built it, own what it touches and answer for it. Sold at four levels, from a pack to a named professional's sign-off.

NEXT

Authorise and accept

A licence with a named owner and an expiry; a risk register built from the gap rather than from a workshop; acceptance carried up to the board on a record instead of a slide.

THEN

Price and insure

The same record, read by an underwriter: explicit scope, the open questions named, and the residual risk owned by somebody. Renewal starts from a record instead of a questionnaire.

ON SALE TODAY

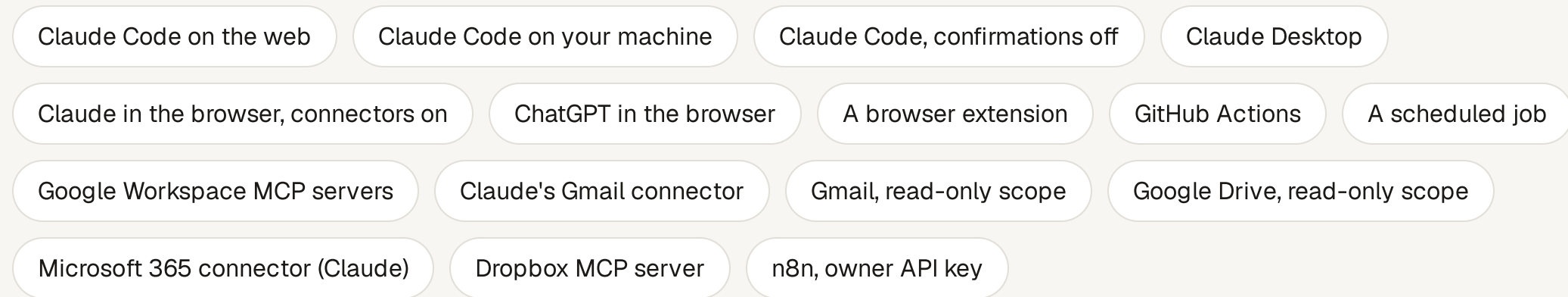
16 published free. Four levels when you want yours.

LEVEL	PRICE	WHEN IT ARRIVES	WHO DOES THE WORK
1 · ABP Pack	£10	immediately	automated
2 · ABP Vault	£50	1 to 2 days	automated
3 · ABP Tailored	£500	1 to 3 days from your reply	a person corrects it
4 · ABP Reviewed	£1,500	1 to 5 days from your reply	two sessions, then a signature

Every level is the same document; what changes is how it arrives and who does the correcting. Prices read from store.sgit.ai on 22 September 2026. Before any of it: 16 template policies published with their read keys, and a free twenty-minute route to write your own against the assistant you already run.

WE INTEGRATE WITH EVERYBODY

16 deployment shapes, and the next one is a file rather than a product.



Coding agents, desktop assistants, browser agents, mail and drive connectors, workflow engines and scheduled jobs, across Anthropic, OpenAI, Google, Microsoft, GitHub, Dropbox and n8n. A shape is described from the vendor's own published pages, quoted and dated, or measured on a deployment we are entitled to run. We never test somebody else's system.

Every vault carries the articles and techniques it touches.

EU AI ACT · 7 ARTICLES

Art. 4 AI literacy · Art. 9 Risk management system · Art. 12 Record-keeping · Art. 13 Transparency and provision of information to deployers · Art. 14 Human oversight · Art. 26 Obligations of deployers of high-risk AI systems · Art. 50 Transparency obligations for providers and deployers of certain AI systems

GDPR · 10 ARTICLES

Art. 5, Art. 6, Art. 24, Art. 25, Art. 28, Art. 29 and 4 more, by article number and title.

MITRE ATT&CK · 14 TECHNIQUES

T1114 Email Collection · T1114.002 Email Collection: Remote Email Collection · T1114.003 Email Collection: Email Forwarding Rule · T1534 Internal Spearphishing · T1566 Phishing ...

Ids and titles only, linked from the consequences in the policy. A link says a provision is **touched**, never that anything complies. Alongside: ISO/IEC 42001, ISO/IEC 27001, NIST AI RMF and the OWASP Agentic Top 10 as the frames underwriters are adopting. This is what lets one record answer the questionnaire somebody else already has.

The policy is a graph. A document is a projection of it.

RUNNING

Behaviours are nodes

A fixed vocabulary of capability ids shared by every vault.

execute.process.host is remote code execution; **delete.file.host** is data deletion. Ids, so they can be linked, counted and compared.

RUNNING

Rows are edges; the barrier sits on the path

Each row carries the door it goes through, the evidence tier, how reversible it is, and what stands in the way. The prompt that regenerates the document ships inside the vault.

IN DESIGN

A view per stakeholder

Operator, security, leadership and insurer each read a projection of the same record. Scenarios already do this on one axis; audiences are the next.

One record, several readers, and connections outward to the standards and techniques each behaviour touches: that is what makes it deployable in an organisation that already has a risk register, an auditor and a broker.

The risk is derived from the record, and owned by a name.

CONSEQUENCES

What follows when a capability meets an asset: read, act, exfiltrate, disrupt, impersonate, outlive. Each one names what it requires and the articles it touches.

WHO HOLDS THE BARRIER

A scope you consented to and can revoke is a different object from a product decision a vendor can change in a release. Both are recorded; the difference is in the facts, not an adjective.

VALIDITY

Every policy says what it describes, as at which date, and what makes it void: a release, a setting, a connector enabled. If the risk changed, the deployment changed.

ACCEPTANCE

A licence to operate with a named owner and an expiry, and a maturity model for how acceptance travels up to the board. The policy carries no score; the acceptance carries a name.

WHY THIS YEAR

Three things changed, and none of them was us.

1 JANUARY 2026

Cover started being withdrawn

A generative-AI exclusion took effect in the standard liability forms much of one large insurance market runs on. Several carriers have filed their own, one of them absolute.

9 MARCH 2026

Responsibility was assigned

A national consumer regulator said a business is responsible if an agent it uses does something illegal, and should be clear what the agent may do and what data it can access.

REGULATION (EU) 2024/1689

Residual risk must be judged acceptable

For high-risk AI systems, Article 9(5) requires the residual risk of each hazard, and overall, to be *judged to be acceptable*. Somebody has to do the judging, and they need a record to judge from.

The first two are sourced and dated on riskmandate.ai/insurance.html. The third is quoted from the regulation as published, read 24 September 2026.

DELIVERED BY PEOPLE, CHECKABLE BY ANYONE

The sign-off carries a name and a date. The method carries its keys.

A named professional signs the top level

Two half-hour sessions with your team, the policy built from the interview rather than from a form, and a security professional who corrects it and signs it. Every line about a reviewer is read off a page they publish themselves, with the date; nobody is scored or ranked.

Open source, and the keys are printed

16 behaviour policies published in full with their read keys. Every page in a public repository: code Apache-2.0, pages and policies CC BY 4.0. Model-drafted and marked as such, with what was measured kept apart from what was documented.

Start with the agent you cannot describe.

One agent, already running, written down as a record you keep and correct. Then the licence, then the acceptance, then the cover. The direction is set; the first step is on sale.

READ ONE FREE

riskmandate.ai

WRITE YOUR OWN

riskmandate.ai/try-it.html

BUY ONE

store.sgit.ai